

Ce TP consiste à activer des services Réseau et à tester le chiffrement des données en utilisant des *certificats*.

Il est recommandé de réaliser une **copie de sauvegarde** de chaque fichier système avant de l'éditer pour les besoins du TP. La majeure partie des commandes sont utilisables uniquement sous l'identité du **root** (avec la commande **sudo**).

Livrables Ce TP donnera lieu à un compte-rendu par **binôme** (ou monôme éventuellement). Vous avez le droit d'insérer des captures d'écran mais toute copie sera pénalisée. Ce compte-rendu doit être déposé sur le dépôt UPdago prévu à cet effet. Les conditions suivantes doivent être respectées:

- le compte-rendu doit être exporté au format PDF;
- si plusieurs fichiers sont rendus, déposer seulement une archive au format ZIP;
- le nom du fichier déposé doit être au format *nom1_nom2.pdf* ou *nom1_nom2.zip*.

La plupart des commandes nécessitent des droits d'accès administrateur. Elles devront donc être précédées par la commande **sudo**, qui demandera de temps à autre le mot de passe (**secu_res_2025**).

1 FTP Sécurisé

FTPS (*Secure File Transfer Protocol*) est le protocole **FTP** couplé au protocole **SSL** (*Secure Socket Layer*). **SSL** permet à un client de vérifier l'identité du serveur auquel il accède grâce à un certificat d'authentification et de chiffrer la communication.

Il fonctionne ainsi:

1. Envoi d'un message **Hello** depuis le client vers le serveur.
2. Réponse du serveur qui transmet son certificat au format **X.509**¹.
3. Le client analyse le certificat et vérifie les informations.
4. Le client s'authentifie auprès du serveur en lui envoyant son propre certificat et une clé pour le chiffrement symétrique, le tout chiffré avec la clé publique du serveur.
5. Le serveur vérifie la validité du certificat reçu.
6. Les données sont échangées entre le client et le serveur, chiffrées avec la clé symétrique.

1.1 Configuration du serveur Pure-FTPd

Ce serveur permet d'échanger des données via le protocole **FTP(File Transfer Protocol)**, sans chiffrement par défaut. Les étapes suivantes vont produire des paramètres de sécurité qui permettront ensuite d'activer les communications sécurisées.

1. Vérifiez que ce service a bien démarré automatiquement avec la commande

```
systemctl status pure-ftpd
```

Pour quitter l'affichage qui apparaît, appuyer sur 'q'.

2. Entrez la commande suivante, qui crée un fichier nommé **TLS**, dans le dossier **/etc/pure-ftpd/conf** et inscrit la valeur 2 dans ce fichier:

```
echo 2 | sudo tee /etc/pure-ftpd/conf/TLS
```

Cette valeur 2 signifie que l'on veut communiquer uniquement en utilisant le chiffrement **TLS**.

¹<https://en.wikipedia.org/wiki/X.509>

1.2 Configuration du certificat pour le chiffrement

1. Créer un répertoire nommé `SSL` dans `/etc/pure-ftpd`.
2. Dans le répertoire `SSL` que vous venez de créer, entrer la commande ci-dessous (sur une seule ligne), en répondant à chaque question. Le certificat et la clé privée auront pour nom `NOM_PRENOM_CERT.cert.pem` et `NOM_PRENOM_PRIV.key.pem`. Remplacer `NOM_PRENOM` par des termes personnalisés. Identifier en particulier l'algorithme utilisé et la longueur de clé choisie.

ATTENTION: la question "Common Name" nécessite de fournir le nom réellement affecté à votre ordinateur ; par défaut, il s'agit de `localhost`.

```
sudo openssl req -x509 -nodes -days 365 -newkey rsa:3072 -out NOM_PRENOM.cert.pem -keyout  
NOM_PRENOM_PRIV.key.pem
```

3. Limiter les accès au fichier contenant la clé privée au propriétaire et aux membres du groupe avec la commande `chmod`.
4. Le certificat et la clé privée doivent être combinés en un unique fichier nommé `pure-ftpd.pem` situé dans `/etc/ssl/private`. Toujours depuis le dossier `SSL`, entrer la commande:

```
sudo cat NOM_PRENOM_CERT.cert.pem NOM_PRENOM_PRIV.key.pem | sudo tee /etc/ssl/private/pure-ftpd.pem
```

5. Faites en sorte que seul l'administrateur puisse lire et écrire dans ce fichier.
6. Il faut maintenant générer des paramètres supplémentaires pour le chiffrement, avec la commande:

```
sudo openssl dhparam -out /etc/ssl/private/pure-ftpd-dhparams.pem 3072
```

Remarque: la génération peut prendre du temps, il faut être patient.e.

7. Vous pouvez redémarrer le service:

```
sudo systemctl restart pure-ftpd
```

8. Vérifiez que ce service à bien redémarré :

```
systemctl status pure-ftpd
```

1.3 Création des fichiers de transfert

Deux utilisateurs, `ftptest1` (mot de passe "`ftptest1`") et `ftptest2` (mot de passe "`ftptest2`"), existent déjà sur le système. Il s'agit maintenant de créer des fichiers qui seront transférés de part et d'autre de ces utilisateurs.

La manipulation suivante s'applique pour `ftptest1`.

1. Se connecter en tant que `ftptest1` avec la commande

```
su ftptest1
```

2. Après connexion, on est resté dans le dossier de l'utilisateur `securite`. Rendez-vous dans le dossier de connexion de `ftptest1`.
3. Créer un dossier `FTP`, puis, dans ce dossier, deux sous-dossiers `prive` et `public`.
4. Par défaut, tous les dossiers sont accessibles en lecture. Modifier les droits d'accès du dossier `prive` pour que personne, à part `ftptest1`, ne puisse y accéder. Cela empêchera un autre utilisateur de lire le contenu de ce dossier.
5. L'objectif du dossier `public` est de donner un accès total à ce dossier à tout le monde, pour y récupérer et y déposer des fichiers. Modifier les droits d'accès à ce dossier pour le permettre.
6. Placer un fichier quelconque (son contenu importe peu) dans `FTP/prive` et un autre dans `FTP/public`.

7. Pour se déconnecter et revenir à l'utilisateur initial `securite`, entrer la commande

```
exit
```

8. Reproduire l'ensemble de la procédure du l'utilisateur `ftptest2`.

1.4 Test de connexion

Ce test consistera à se connecter en tant que `ftptest1` et de transférer un fichier vers l'utilisateur `ftptest2`² via un logiciel FTP client spécifique nommé `filezilla`.

Attention : par défaut, les utilisateurs ajoutés sur le système (`ftptest1` et `ftptest2` dans notre cas) ne peuvent pas exécuter des logiciels graphiques depuis la ligne de commande. Un moyen d'y remédier est d'entrer au préalable la commande suivante:

```
sudo xhost +
```

1. Depuis un terminal, se connecter en tant qu'utilisateur `ftptest1`, puis exécuter le logiciel client `FTP`

```
filezilla
```

et préciser

- dans le champ `Hôte` le nom du serveur FTP (`localhost` par défaut)
- dans le champ `Identifiant` : `ftptest1`
- dans le champ `Mot de passe` : `ftptest1`

Puis cliquer sur `Connexion rapide` (inutile de préciser le numéro de port).

2. Dans la fenêtre suivante, vous pouvez ou non enregistrer le mot de passe pour une utilisation future.
3. Une fenêtre nommée "*Certificat inconnu*" contenant les informations entrées précédemment devrait apparaître. Ce certificat est "inconnu" dans la mesure où il n'a pas été créé par une autorité de certification officielle. Mais peu importe ici : cette fenêtre prouve que votre certificat a bien été enregistré. Vérifier que les informations listées dans ce certificat correspondent aux réponses fournies lors l'utilisation de la commande `openssl`, puis cliquer sur `OK` pour valider le certificat.
4. Une autre fenêtre "*Données de connexion FTP non sécurisée*" devrait s'afficher. Elle concerne uniquement les cas où une session FTP se déroule en plusieurs fois, on peut ignorer ici cet avertissement.
5. Dans la partie *gauche* de l'interface, le *site local* mentionne `/home/ftptest1`. Se rendre dans le dossier `/home/ftptest1/FTP/public` pour afficher son contenu.
6. Dans la partie *droite* de l'interface, se déplacer dans le *site distant* jusqu'au dossier `/home/ftptest2/FTP` pour afficher son contenu.
7. Vérifier que le dossier `/home/ftptest2/FTP/privé` n'est pas accessible en cliquant dessus.
8. En revanche le dossier `/home/ftptest2/FTP/public` devrait être accessible, toujours en cliquant dessus.
9. Revenir dans la partie gauche de l'interface et cliquer avec le bouton **droit** sur le fichier contenu dans `/home/ftptest1/FTP/public` et sélectionner `Téléverser`. Le fichier devrait être transféré vers `/home/ftptest2/FTP/public`.
10. Réciproquement, cliquer avec le bouton droit sur le fichier que vous aviez placé dans `/home/ftptest2/FTP/public` et sélectionner `Télécharger`. Le fichier devrait être transféré dans `/home/ftptest1/FTP/public`.
11. Quitter `filezilla`.

²La communication se fera sur le même ordinateur, mais fonctionnerait de manière identique entre ordinateurs distants

1.5 [Optionnel] Analyse de trames avec wireshark

wireshark³ est un outil capturant les flux réseaux et permettant de scruter leur contenu.

1. Démarrer **wireshark** en tant que super-utilisateur et tester de nouveau un transfert de fichier avec **filezilla**.
2. Une liste d'interfaces réseau à capturer est affichée. Double-cliquer sur **loopback:lo**.
3. Redémarrer **filezilla** en tant qu'utilisateur **ftptest1** et se connecter comme précédemment.
4. Parmi le début des messages enregistrés dans **wireshark**, repérer les premiers échanges entre le client et le serveur FTP (utilisant justement le protocole **FTP** et le protocole **TCP**).
5. Repérer ensuite les messages indiquant que le protocole de chiffrement **TLS** est activé.
6. Transférer de nouveau un fichier depuis **/home/ftptest1/FTP/public** vers **/home/ftptest2/FTP/public**. Repérer les communications correspondantes dans **Wireshark** (indice: le client commence par envoyer un message "**Hello**" au serveur qui lui répond, avant d'entamer le transfert proprement dit).
7. Quitter **wireshark** (inutile d'enregistrer les informations de session).
8. Quitter **filezilla**.

2 HTTPS

Un serveur **HTTP** est déjà installé sur la machine virtuelle. L'objectif de cette partie est d'utiliser le même ordinateur pour communiquer avec un serveur utilisant le protocole **HTTPS**.

Comme précédemment, la majeure partie des commandes devront être précédées par la commande **sudo**.

2.1 Test du serveur HTTP

En tant qu'utilisateur par défaut (**securite**), vérifier que le serveur **HTTP** installé par défaut fonctionne avec la commande suivante.

```
sudo service apache2 status
```

apache2 est le nom du logiciel serveur choisi pour exécuter le protocole **HTTP**⁴.

Parmi le bloc de texte émis par cette commande, les mots **active (running)** devraient s'afficher.

Ouvrir maintenant un navigateur Web (**firefox** est disponible par défaut) et entrer l'URL

```
http://localhost
```

La page d'accueil "*Apache2 Default Page*" devrait s'afficher.

En revanche, si on entre l'URL (noter le 's' dans **https**)

```
https://localhost
```

Une erreur est affichée : le protocole **HTTPS** n'est pas activé (c'est un peu le but du TP d'y parvenir)...

2.2 Configuration de HTTPS

2.2.1 Un nouveau nom de serveur

Pour commencer, un nouveau nom de serveur Web va être déterminé pour éviter d'utiliser **localhost**. Une manière de procéder sous **Linux** est d'éditer le fichier **/etc/hosts**. Ce fichier texte représente une manière de stocker les correspondances entre les adresses IP et les noms de machines

Attention: le fichier **/etc/hosts.sav** est un fichier de sauvegarde en cas de fausse manœuvre. **NE PAS modifier ce fichier.**

Éditer (en tant que super-utilisateur) **/etc/hosts** pour ajouter la ligne suivante au début de fichier, en choisissant un nom de site web basé sur vos nom et prénom.

```
127.0.0.2 NOM_PRENOM.org
```

³<https://www.wireshark.org>

⁴Plus d'informations sur ce site

Plusieurs lignes de ce fichier ont une adresse commençant par `127`. Que se passe-t-il si l'une de ces adresses (ou le nom associé) est entrée comme URL dans le navigateur?

Désormais, on peut contacter un ordinateur directement par son nom. En l'identifiant que vous avez choisi à la place de `NOM_PRENOM.org`, entrer les commandes (l'option `-c 4` spécifie le nombre de `ping` envoyés).

```
ping -c 1 127.0.0.2
ping -c 1 NOM_PRENOM.org
```

2.2.2 Configuration de SSL

`apache2` propose déjà tous les *plugins* (nommés aussi "*modules*") pour configurer les connexions sécurisées. Il s'agit ici de créer un serveur spécifique qui manipulera ces outils. Toutes les commandes sont entrées en tant que super-utilisateur.

1. Dans `/etc/apache2`, créer un répertoire au format `NOM_PRENOM_HTTPS` basé sur vos nom et prénom et s'y rendre⁵.
2. On reprend l'utilisation de `SSL` expliquée dans la section 1.2. Générer avec `openssl` deux nouveaux fichiers équivalents à `SKAPIN_XAVIER.cert.pem` et `SKAPIN_XAVIER_PRIV.key.pem` en précisant dans le champ "`Common Name`" le nom personnalisé du serveur qui vient d'être écrit dans `/etc/hosts`.
3. Activer le "module" `SSL` d'`Apache` avec la commande (`a2enmod` est une abréviation pour "*apache2 enable module*")

```
sudo a2enmod ssl
```

4. Dans le dossier `/var/www`, créer un sous-dossier `NOM_PRENOM_WWW` basé sur vos nom et prénom et y créer un fichier `index.html` contenant un texte quelconque au format `HTML`, par exemple

```
<h1> Serveur HTTPS pour NOM PRÉNOM </h1>
```

De manière générale, c'est dans ce dossier que toutes les données relatives à votre serveur Web seront stockées.

5. Le module `ssl` a été activé dans une étape précédente. Il faut maintenant le paramétrer avec vos données de chiffrement (en particulier, les clés générées avec `openssl`). Ce paramétrage est déterminé dans un fichier de configuration *ad hoc*.

Copier le fichier de configuration SSL par défaut `/etc/apache2/sites-available/default-ssl.conf` sous le nom `/etc/apache2/sites-available/NOM_PRENOM_SSL.conf` et modifier son contenu de la manière suivante (ajouter directement la ligne avec `ServerName` dans ce fichier):

```
ServerAdmin webmaster@NOM-DEFINI-DANS-LE-FICHER-HOSTS

ServerName NOM-DEFINI-DANS-FICHER-LE-FICHER-HOSTS

DocumentRoot CHEMIN-VERS-DOSSIER-CONTENANT-LE-FICHER-INDEX.HTML-PERSONNALISE

SSLEngine on

SSLCertificateFile CHEMIN-VERS-NOM_PRENOM_CERT.pem

SSLCertificateKeyFile CHEMIN-VERS-NOM_PRENOM_CLE_PRI.pem
```

Remarque : si la directive `ServerName` n'est pas définie, ajouter la ligne dans le fichier en suivant le modèle indiqué.

6. Le répertoire `/etc/apache2/sites-available` liste les configurations des sites *disponibles*, mais ces sites ne sont pas actifs par défaut. Pour activer votre site, entrer successivement les commandes suivantes (`a2ensite` signifie "*apache2 enable website*"):

```
sudo a2ensite NOM_PRENOM_SSL.conf
sudo systemctl reload apache2
```

En cas de problème, désactiver le site avec la commande `a2disssite` (pour "*apache2 disable website*") et analyser le fichier `/var/log/apache2/error.log`.

⁵Un répertoire de secours `/etc/apache2.sav` existe déjà. **NE PAS le modifier.**

7. Vérifier que le serveur a démarré correctement :

```
sudo service apache2 status
```

8. Dans le navigateur, entrer l'URL : `https://NOM-DEFINI-DANS-FICHER-HOSTS`.

Comment interpréter l'avertissement qui s'affiche ? Que faire pour passer outre cet avertissement?

Vérifier que l'URL `http://localhost` renvoie toujours sur la page par défaut d'`Apache` : les deux sites fonctionnent bien en parallèle.

2.3 [Optionnel] Analyse de trames avec wireshark

Utiliser de nouveau `wireshark` pour afficher les informations relatives au protocole `TLS` (qui gère `HTTPS`) lors des connexions au serveur.